

Lecture 09: Botnet, DDoS, APT

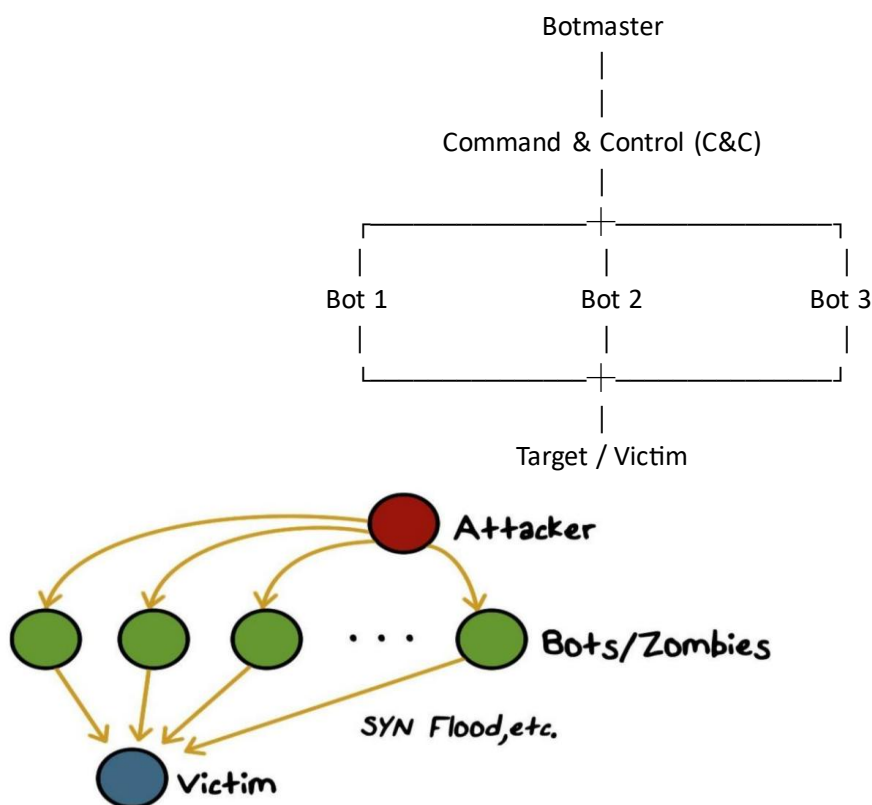
Definition

A Botnet is a network of compromised computers (called bots or zombies) that are remotely controlled by an attacker, known as the Botmaster, to perform coordinated malicious activities. Each infected computer runs bot malware, which communicates with the attacker's Command and Control (C&C) server and executes commands such as launching attacks, sending spam, or stealing data.

What is a Bot (Zombie)?

A Bot (also called a Zombie) is a computer that has been infected with malware and is secretly controlled by an attacker without the owner's knowledge. The infected computer appears normal to the user but continuously communicates with the attacker's server to receive commands.

Botnet Architecture



Components of a Botnet

1. Botmaster

- Controls the entire botnet.
- Sends commands to infected computers.

2. Bots (Zombies)

- Compromised computers.
- Execute malicious instructions.

3. C&C Server

- Communication channel between botmaster and bots.
- Sends updates and attack commands.

4. Victim

- Target of attacks such as DDoS or spam.

How a Botnet is Created

Step 1

Attacker develops malware.

↓

Step 2

Malware spreads through:

- Email attachments
- Malicious websites
- Fake software
- USB drives
- Social engineering

↓

Step 3

Victim executes malware.

↓

Step 4

Computer becomes a Bot.

↓

Step 5

Bot connects to C&C server.

↓

Step 6

Attacker controls thousands of infected computers.

Botnet Communication

Bots continuously communicate with the Command & Control (C&C) server to:

- Report their status.
- Receive malware updates.
- Download additional malicious software.
- Receive commands such as sending spam, launching phishing campaigns, or performing DDoS attacks.

Attacks Performed by Botnets

Botnets are responsible for many Internet-based attacks and frauds. Common attacks include:

1. Spam

Sending millions of unwanted emails.

2. Distributed Denial of Service (DDoS)

Flooding a target server with enormous traffic until it becomes unavailable.

3. Key Logging

Recording every key pressed by the victim to steal usernames, passwords, and banking information.

4. Identity Theft

Stealing personal information for fraud.

5. Password Cracking

Using bots to perform large-scale password guessing attacks.

6. Click Fraud

Automatically clicking online advertisements to generate illegal advertising revenue.

7. Phishing

Creating fake websites or emails to steal confidential information.

8. Pharming

Redirecting users from legitimate websites to fake websites.

9. Online Game Cheating

Automating actions inside online games or manipulating online polls.

10. Anonymous Criminal Communication

Using botnets as anonymous communication channels for cybercriminals or terrorist groups.

DDoS Attack

A Distributed Denial of Service (DDoS) attack is a cyberattack in which multiple compromised computers (bots) simultaneously send massive traffic to a target server or network, exhausting its resources and making services unavailable to legitimate users.

Difference Between DoS and DDoS

DoS	DDoS
Single attacking computer	Many attacking computers
Easier to stop	Very difficult to stop
Small traffic	Massive traffic
Less dangerous	Highly dangerous

DDoS Using Botnets

Working Process

1. Attacker controls many bots.
2. Attacker sends attack command.
3. Every bot sends requests to the victim simultaneously.
4. Victim's bandwidth, CPU, or memory becomes overloaded.
5. Legitimate users cannot access the service.

Common examples include **SYN Flood**, HTTP Flood, and UDP Flood attacks.

Amplified Distributed Reflective Attack (ADRA)

An Amplified Distributed Reflective Attack is a DDoS attack where attackers send small spoofed requests to public servers (reflectors), which generate much larger responses that are sent to the victim. The victim receives enormous traffic without directly communicating with the attacker.

DNS Amplification Attack

Step 1

Attacker spoofs the victim's IP address.

↓

Step 2

Small DNS request is sent to an open recursive DNS server.

↓

Step 3

DNS server returns a much larger response.

↓

Step 4

Large response is delivered to the victim.

↓

Step 5

Thousands of servers repeat this process, overwhelming the victim.

The lecture illustrates how a small DNS request (around 60 bytes) can trigger a response exceeding 1500 bytes, greatly amplifying attack traffic.

Why Amplification is Dangerous

- Small attacker bandwidth.
- Huge victim bandwidth.
- Difficult to trace.
- Reflection hides attacker identity.

Command and Control (C&C)

Command and Control (C&C) is the communication infrastructure that allows a Botmaster to control bots remotely. Without C&C, bots cannot receive instructions or coordinate attacks.

Functions of C&C

- Send attack commands.
- Update malware.
- Collect stolen data.
- Receive bot status.
- Coordinate attacks.

Botnet C&C Problem

After malware infects many victims, the attacker must still communicate with those compromised systems. The challenge is to build a communication mechanism that is:

- Hidden.
- Reliable.
- Difficult to block.

Simply infecting machines is not enough—the attacker also needs an effective way to control them.

Naive C&C Approach

IDEA: Every infected computer directly contacts one fixed server controlled by the attacker.

Problems

1. Not Stealthy

Malware contains the attacker's address.

2. Single Point of Failure

If the server is shut down, the entire botnet stops working.

3. Hard-coded Address

Changing the server location requires changing the malware itself. These weaknesses make the design easy to disrupt.

Better C&C Design Requirements

A good C&C system should be:

Efficient: Reach many bots quickly.

Reliable: Deliver commands successfully.

Stealthy: Blend into normal network traffic.

Resilient: Remain operational even if some servers are blocked. These design goals make botnets more difficult to detect and disable.

Advanced Persistent Threat (APT)

An Advanced Persistent Threat (APT) is a highly sophisticated, targeted cyberattack in which attackers **gain unauthorized access to a network** and remain hidden for a long period while stealing information or causing damage. Unlike ordinary malware, an APT focuses on specific organizations and operates slowly to avoid detection.

Meaning of APT

Advanced

- Uses specially crafted malware.
- Skilled attackers.
- Advanced techniques.

Persistent

- Long-term attack.
- Continuous presence.
- Multi-stage operation.
- "Low and Slow" strategy.

Threat

Targets:

- Government
- Military
- Banks
- Research organizations
- Large companies

APT Lifecycle

Typical lifecycle:

Choose Target

|

Research Organization

|

Create Malware

|

Deploy Malware

|

Establish Communication

|

Remain Hidden

|
Steal Data

|
Maintain Access

The lecture diagram includes defining the target, researching infrastructure and employees, testing for detection, deployment, establishing outbound connections, exfiltrating data, and remaining undetected.

Characteristics of APT

1. Zero-Day Exploit

Uses vulnerabilities unknown to software vendors.

2. Custom Malware

Specially designed for a specific target.

3. Difficult Detection

Traditional antivirus signatures often cannot detect it.

4. Social Engineering

Uses convincing phishing or impersonation attacks to trick even experienced users.

5. Low-and-Slow Attack

Acts gradually to avoid generating suspicious activity.

6. Data Exfiltration

Secretly steals confidential information.

7. Persistence

Maintains long-term access to the target system.

8. Multi-step Attack

Uses several stages rather than a single action.

The lecture also highlights examples such as compromising routers or web servers, using MITM to strengthen social engineering, making small incremental data changes, and moving laterally through networks over time.

Example of an APT Attack

Suppose an attacker targets a bank.

Step 1

Research employees.

↓

Step 2

Send phishing email.

↓

Step 3

Employee opens malicious PDF.

↓

Step 4

Malware installs silently.

↓

Step 5

Attacker gains remote access.

↓

Step 6

Moves laterally across the network.

↓

Step 7

Steals sensitive customer information over weeks or months.

The lecture illustrates this process using malicious PDF documents spreading through targeted systems.

Botnet vs APT

Feature	Botnet	APT
Purpose	Large-scale attacks	Targeted espionage
Victims	Many users	Specific organization
Duration	Short or repeated	Long-term
Malware	Generic	Customized
Detection	Easier	Very difficult
Goal	Spam, DDoS, fraud	Steal confidential information

DDoS vs APT

DDoS	APT
Makes service unavailable	Steals sensitive information
Immediate impact	Long-term impact
Large amount of traffic	Minimal, stealthy traffic
Easy to notice	Hard to detect
Availability attack	Confidentiality-focused attack

Advantages (Attacker's Perspective)

Botnet

- Large computing power.
- Anonymous attacks.
- Easy to coordinate.
- Difficult to trace.

APT

- High success rate.
- Long-term access.
- Valuable information theft.
- Difficult detection.

Defensive Measures

Against Botnets

- Install antivirus software.
- Update operating systems.
- Avoid suspicious downloads.
- Use firewalls.
- Detect unusual network traffic.
- Disable unnecessary services.

Against DDoS

- Traffic filtering.
- Rate limiting.
- Load balancing.
- CDN protection.
- DDoS mitigation services.

Against APT

- Multi-factor authentication (MFA).
- Employee security awareness training.
- Network segmentation.
- Endpoint Detection and Response (EDR).
- Continuous monitoring.
- Patch systems regularly.
- Long-term persistence.
- Social engineering.
- Low-and-slow operation.
- Data exfiltration.
- Multi-stage attacks.